

THRESHOLD ENTERPRISE SYSTEMS

AI Data Privacy Policy

Document Id	AIG-006
Title	AI Data Privacy Policy
Department	Enterprise Governance
Classification	CONFIDENTIAL
Version	1.0
Status	ACTIVE
Effective Date	2026-01-15
Document Type	POLICY
Allowed Roles	MANAGER, AI_ENGINEER, SECURITY_ENGINEER, HR_MANAGER, ADMIN

1. CONFIDENTIAL CLASSIFICATION AND OPERATIONAL PURPOSE

*** CONFIDENTIAL DOCUMENT - RESTRICTED TO MANAGERIAL AND TECHNICAL GOVERNANCE ROLES ***

This document establishes the proprietary data privacy standards, anonymization protocols, retrieval boundary controls, and regulatory compliance requirements governing all data utilized across artificial intelligence pipelines at Threshold Enterprise Systems. It is classified as CONFIDENTIAL. Access is restricted to authorized roles (MANAGER, AI_ENGINEER, SECURITY_ENGINEER, HR_MANAGER, ADMIN). Workforce members holding the general EMPLOYEE role are not authorized to retrieve this document within the knowledge base.

The purpose of this AI Data Privacy Policy is to ensure that all data ingested, trained upon, fine-tuned, indexed, retrieved, or generated by enterprise AI systems adheres strictly to global data protection laws—including the European Union General Data Protection Regulation (EU GDPR), the UK GDPR, the California Consumer Privacy Act as amended by the CPRA, the Digital Personal Data Protection Act of India (DPDP Act 2023), and the Singapore Personal Data Protection Act (PDPA)—and harmonizes seamlessly with our enterprise data classification taxonomy established in SEC-005.

In an era where large language models and vector search architectures ingest vast corporate datasets, the risk of accidental exposure of personal data, training data memorization, and unvetted cross-border data transfer increases exponentially. This policy provides the technical architecture and compliance governance necessary to build and maintain privacy-preserving AI systems.

2. Alignment with Enterprise Data Classifications (SEC-005)

All data utilized across artificial intelligence pipelines must be categorized under the four standardized enterprise tiers defined in SEC-005 (Data Classification and Handling Policy):

- PUBLIC Data:** Open-source documentation, published research, and public product guides. May be utilized for model pre-training, fine-tuning, RAG ingestion, and public prompt engineering without privacy restrictions.
- INTERNAL Data:** General corporate documentation, internal policies, and non-sensitive project descriptions. May be indexed in internal enterprise RAG systems and used for internal fine-tuning, accessible broadly across authenticated enterprise roles.
- CONFIDENTIAL Data:** Sensitive operational records, proprietary algorithms, financial models, HR performance files (HR-006), and personnel records (HR-007). May be ingested into department-scoped RAG indexes only with strict metadata-based permission filters. Models fine-tuned on CONFIDENTIAL data inherit the CONFIDENTIAL classification and must enforce departmental role-based access control.

4. RESTRICTED Data: Master cryptographic keys, security breach forensics (SEC-004), and production access break-glass tokens (SEC-007). STRICTLY FORBIDDEN from general AI model training or broad RAG indexing. RESTRICTED data may only be processed within dedicated, air-gapped, zero-trust analytical enclaves under dual-custody authorization.

3. Core Data Privacy Principles in AI Engineering

Every AI system engineered, deployed, or operated by Threshold Enterprise Systems must embed five foundational privacy principles:

1. Data Minimization: Data science squads must ingest and retain only the minimal volume of data strictly necessary to train, fine-tune, or ground model capabilities. Unnecessary biographical, geographical, or transactional data must be excised prior to vectorization or model ingestion.
2. Purpose Limitation: Data gathered for one legitimate enterprise purpose (e.g., employee payroll processing under HR-007) must never be repurposed for AI model training or predictive behavioral scoring without fresh legal review and explicit authorization from the Data Protection Officer.
3. De-Identification, Masking, and Anonymization: Direct identifiers (names, SSNs, national tax IDs, email addresses, phone numbers, passport numbers) must be sanitized from training corpora and RAG document repositories using automated Named Entity Recognition (NER) token masking and k-anonymity techniques.
4. Synthetic Data Prioritization: Wherever technically viable, engineering teams are encouraged to generate high-fidelity synthetic training and evaluation datasets to avoid exposing real customer or employee personal records during algorithmic development.
5. Storage and Context Limitation: Transient user prompts and inference interactions must be flushed from memory upon session conclusion. Commercial third-party LLM providers must maintain zero-retention contractual agreements.

4. Data Lifecycle in AI: Training, Fine-Tuning, and Inference

Privacy controls must operate across all three distinct phases of the AI lifecycle:

- Pre-Training and Fine-Tuning Corpora: Datasets compiled for model weight modification must undergo automated scanning by the Data Privacy Office to verify copyright legality, license compatibility, and absence of sensitive PII. Embeddings and weights trained on sensitive corpora must undergo extraction testing to confirm memorization resistance.
- RAG Knowledge Bases and Embedding Pipelines: Documents ingested into vector databases must preserve original classification metadata, allowed roles, and document version attributes. Embeddings must be generated using approved, isolated embedding models operating within the enterprise security boundary.
- Inference and Prompt Context: User prompts and retrieved contextual chunks must be protected against prompt injection exfiltration (AIG-007). In-memory contextual buffers must be scrubbed upon completion of response generation.

5. Technical Data Sanitization Standards: Token Masking, K-Anonymity, and L-Diversity

Prior to ingesting unstructured operational text into RAG indexes or fine-tuning datasets, data engineering squads must apply automated sanitization pipelines:

- Named Entity Recognition (NER) Scrubbing: Automated scanning pipelines identify, redact, or pseudonymize twenty-seven categories of Personally Identifiable Information (PII) using consistent cryptographic salt tokens (e.g., replacing employee names with deterministic surrogate keys [EMPLOYEE_REF_9812]).
- K-Anonymity and L-Diversity Thresholds: Tabular training datasets containing quasi-identifiers (such as age, department, office location, job grade) must satisfy k-anonymity ($k \geq 5$) and l-diversity ($l \geq 3$) to prevent re-identification linkage attacks against corporate staff.
- Cryptographic Hash Salting: Direct identifiers that must be retained for longitudinal research must be irreversibly hashed using SHA-256 with an enterprise master salt managed within Hardware Security Modules (HSMs).

6. Vector Store Isolation and Multi-Tenant Privacy Boundaries

Enterprise RAG architectures present specialized data leakage vectors where unprivileged users might retrieve vectorized representations of sensitive documents. To mitigate this risk, the following controls are mandatory:

- Partition-Level Metadata Isolation: Vector database indices must enforce strict metadata segregation. Every indexed chunk must retain immutable attributes: classification, department, document_id, allowed_roles, and tenant_id.
- Pre-Query Permission Filtering: Vector similarity search engines must execute pre-filtering—restricting nearest-neighbor vector calculations exclusively to chunks where the querying user's authenticated roles match the chunk's allowed_roles. Post-filtering (retrieving chunks and then discarding unpermitted ones) is strictly prohibited due to similarity score leakage.
- Tenant Partitioning: In multi-tenant SaaS environments, customer vector embeddings must reside in physically separated database schemas or cryptographically distinct tenant namespaces, preventing cross-customer data bleeding.

7. Differential Privacy and Membership Inference Resistance

To prevent attackers from determining whether an individual's specific record was included in training corpora via membership inference attacks, engineering squads must enforce differential privacy baselines:

- Epsilon Privacy Budgets: Machine learning training algorithms operating on personal data must implement differentially private stochastic gradient descent (DP-SGD) with an aggregate privacy loss parameter (epsilon) strictly bounded below 4.0 and delta below 1e-5.
- Gradient Clipping and Noise Addition: During model optimization, per-sample gradients must be clipped to a fixed L2 norm and calibrated Gaussian noise injected to obscure individual data contributions.
- Membership Inference Auditing: Prior to model certification under AIG-003, models trained on customer or employee data must undergo shadow-model membership inference stress testing to verify empirical resistance.

8. Cross-Border Data Transfers and Sovereign Data Pinning

Threshold Enterprise Systems operates across four distinct sovereign jurisdictions (India, United States, United Kingdom, and Singapore). AI data flows must respect cross-border data transfer mandates:

- Jurisdictional Data Pinning: Datasets originating within India under the DPDP Act or within the European Union / UK under GDPR must not be transferred across geographic boundaries for AI model training without formal Standard Contractual Clauses (SCCs) or verified adequacy decisions.
- Cloud Model Hosting Enclaves: External commercial AI endpoints must be configured to pin inference compute and data storage within the geographic region of data origin (e.g., EU model endpoints for EU client queries, AWS Mumbai enclaves for Indian operations).
- Sovereign Vector Index Partitions: Vector databases must enforce geo-tagging, ensuring that high-sensitivity vector indexes reside solely on cloud infrastructure located within approved geopolitical boundaries.

9. Data Subject Rights, Erasure, and Machine Unlearning

Under global privacy statutes, individuals hold rights to access, rectification, erasure ('right to be forgotten'), and restriction of processing:

- In RAG and Vector Architectures: When a data subject requests erasure under our Data Subject Access Request (DSAR) process, the associated source document is immediately purged from the source repository, its corresponding vector embeddings are dropped from vector indexes, and semantic search caches are invalidated within twenty-four (24) hours.
- In Parametric Foundation Models: Because completely removing individual data points from static neural network weights ('machine unlearning') remains technically challenging, personal data must NEVER be embedded into permanent model weights. All personal data must reside exclusively in modular, purgeable RAG knowledge bases.

- Subject Access Requests (DSARs): The Data Privacy Office maintains dedicated tools to audit whether an individual's personal data appears in active RAG vector partitions, fulfilling export requests within statutory thirty-day windows.

10. Third-Party Commercial AI Services Governance

When integrating third-party commercial AI APIs (e.g., external LLM endpoints), the project sponsor must ensure that the vendor signs our Enterprise Data Processing Agreement (DPA).

The DPA must legally bind the vendor to: zero data retention for training future models; encryption in transit via TLS 1.3; geographic tenant pinning (ensuring Indian, EU, UK, or Singaporean data resides within local sovereign borders); and immediate notification in the event of an infrastructure breach.

Free, public, or uncontracted consumer AI services are strictly prohibited from processing any enterprise data as mandated by the Generative AI Usage Policy (AIG-004).

11. Compliance Auditing, Breaches, and Escalation

The Data Privacy Office conducts quarterly audits of AI training repositories and vector store schemas to verify compliance with privacy rules and metadata integrity.

Any unauthorized leakage of personal data through AI completions or prompt exfiltration must be reported immediately to the Data Protection Officer and Information Security under AIG-009 and SEC-004.

Violations of this policy are subject to disciplinary intervention and regulatory reporting under international statutory frameworks.

12. Cross-Document Governance Interconnections

This policy operates in direct harmony with related enterprise standards:

- SEC-005: Data Classification and Handling Policy (Establishes the enterprise classification tiers).
- AIG-003: AI Model Approval Policy (Mandates privacy validation gate prior to model approval).
- AIG-004: Generative AI Usage Policy (Regulates employee prompt handling and tool usage).
- AIG-007: Prompt Security Policy (Protects contextual data from adversarial extraction).